



Banking-as-a-Service API Audit: Integrated Surface and Issuer Requirements

Zach Kelling

Lux Industries

2026

Abstract

Lux Financial operates a complete banking and card surface — accounts, payments, FX, cards, and crypto settlement — with SF Private Bank LTD (International Banking License L17601/SFPB, Union of Comoros Offshore Finance Authority) as the issuer of record. This audit records the full production surface Lux exposes today, the issuer API surface received to date (the Account Management and Virtual Cards integration guides), and the catalog of issuer APIs still required to activate every remaining product. Each requirement is stated as a concrete endpoint contract with the Lux surface it powers, priced by launch priority. The intent is a single punch list: when the APIs in Section 6 are issued, the full BaaS and CaaS ships through `/v1/bank` and `/v1/cards` — consumer at `lux.finance`, platform at `lux.financial`, and agent access through `api.hanzo.ai`.

1 Introduction

Lux Financial is one ladder of products across three brand surfaces. **lux.finance** is the consumer home — landing, membership plans (Silver \$29 / Gold \$99 / Black \$299 / Sovereign \$999), signup and login through Lux IAM (`lux.id`), and the demonstration surface for the native DeFi stack (Liquid Protocol lending, vaults, non-custodial wallets). **lux.financial** is the business side — the BaaS platform for white-label partners, its documentation at `docs.lux.financial`, and the partner console. **lux.credit** is the card program funnel. Agents and API customers reach the same surface through Hanzo’s unified endpoint, `api.hanzo.ai`, as `/v1/bank` and `/v1/cards`.

Behind all of it sits one issuer abstraction (`luxfi/bank`, `issuer.go`): the banking counterparty is an implementation detail selected at deployment, never an API difference. SF Private Bank is the first live issuer; Banxe (UK, distributor of Tompay LTD, FCA EMI 931509) is second in line. The abstraction is shipped and tested; what remains is upstream API coverage.

Two integration guides have been received from SF Private Bank to date. They cover the card-account and virtual-card lifecycle well, and nothing else. This paper is the complete accounting of the difference between the product surface Lux sells and the issuer surface Lux has been given.

2 Production Surface (Lux Side)

Recorded here as the deployment of record, including the crypto network production value.

Surface	Host	Role
Consumer app + landing	<code>lux.finance</code>	B2C home: plans, signup, login (<code>lux.id</code>)
Card program	<code>lux.credit</code>	Card tiers, comparison, application funnel
DeFi / Liquid Protocol	<code>app.lux.finance</code>	Lending, vaults; merging into the bank app
Platform app	<code>app.lux.financial</code>	White-label / partner surface
Sandbox demo	<code>sandbox.lux.financial</code>	Seeded fixtures, deterministic settlement
B2B marketing + docs	<code>lux.financial</code> , <code>docs.lux.financial</code>	BaaS platform
API (production)	<code>https://api.lux.financial/v1</code>	REST, IAM JWT auth
API (sandbox)	<code>https://api.sandbox.lux.financial/v1</code>	Same contract, fake money
Agent resale	<code>https://api.hanzo.ai/v1/bank</code> , <code>/v1/cards</code>	Unified Hanzo endpoint

Table 1: Production surfaces of record.

Crypto production values. Network identifier `lux-mainnet`; sandbox runs `lux-testnet`. On-chain wallets are non-custodial threshold-MPC wallets attached per account; crypto-to-card set-

tlement is an issuer rail (§6.4). The production RPC surface is the Lux primary network EVM (C-Chain) behind `api.lux.network`.

Service composition. `bankd` (customer of record: accounts, balances, wallets, transactions, beneficiaries, cards, plans), `treasuryd` (rail execution through provider adapters), `forexd` (FX), `amld` (screening and monitoring), Lux IAM (the only authorizer). Membership plans are published at `GET /v1/bank/plans` and drive per-account transaction limits.

3 The Resale Surface — `/v1/bank` and `/v1/cards`

This is the product: the complete API Lux resells as the BaaS and CaaS. Every endpoint is live today. The **Backing** column is the whole audit in one word — *Lux* means the endpoint runs entirely on the Lux stack (`bankd` ledger, `forexd`, `amld`, `lux-mainnet`) and needs nothing from the issuer; a §6 reference names the one complementary issuer API that turns it from sandbox to real money. At `api.hanzo.ai` the card subset publishes as `/v1/cards` (a gateway alias of `/v1/bank/cards`).

Endpoint	Product	Backing
<code>GET /v1/bank/health, /config, /plans</code>	Status, config, membership ladder	Lux
<code>POST /v1/bank/onboard</code>	Account opening from KYC profile	§6.2+6.3
<code>GET /v1/bank/overview, /transactions</code>	Dashboard, activity	Lux
<code>GET /v1/bank/account/summary</code>	Account list	Lux
<code>POST /v1/bank/transfers</code>	Book transfer (own accounts)	Lux
<code>POST /v1/bank/payments/outbound</code>	ACH, wires, checks, P2P	§6.4
<code>GET /v1/bank/accounts/:id/balances</code>	Per-currency balances	Lux; recon §6.3
<code>GET /v1/bank/accounts/:id/wallets</code>	On-chain wallets (<code>lux-mainnet</code>)	Lux
<code>GET /v1/bank/accounts/:id/transactions</code>	Account history	Lux
<code>GET/POST/DELETE /v1/bank/beneficiaries</code>	Counterparties	Lux; verify §6.4
<code>GET/POST /v1/bank/cards, :id/freeze</code>	Card ledger, freeze/unfreeze	§6.5
<code>POST /v1/bank/cards/account</code>	Issuer card account opening	§6.1
<code>GET /v1/bank/cards/account, /kyc</code>	Issuer account + KYC state	§6.1
<code>POST /v1/bank/cards/virtual, /order</code>	Virtual card create + order	§6.1
<code>GET .../virtual/kyc-url, /consent-url</code>	Hosted KYC / consent hand-off	§6.1
<code>POST /v1/bank/exchange/quote, /execute</code>	Fiat FX + crypto buy/sell/convert	Lux
<code>GET /v1/bank/wallet, /crypto/prices</code>	Crypto balances, reference prices	Lux
<code>POST /v1/bank/fx/quote, /execute</code>	Dealt FX (<code>forexd</code> adapters)	Lux
<code>POST .../webhooks/* (HMAC)</code>	Event ingestion	Lux; feeds §6.6

Table 2: The resale surface. *Lux* = runs on the Lux stack alone; §6.x = the complementary issuer backend requested in this audit.

Read the table bottom-up and the shape of the deal is plain: the ledger, dashboard, crypto, FX dealing, plans, and event plumbing are Lux-native and already in production. The complementary backend requested from SF Private Bank is exactly four things — credentials (§6.1), onboarding (§6.2–6.3), payment rails (§6.4), and the card lifecycle (§6.5–6.6). Nothing else is asked.

4 Issuer Surface Received

The two SF Private Bank integration guides document, in full:

Endpoint	Guide	Purpose
POST /account/:userId	Account Mgmt	Create established card account
GET /account/:userId	Account Mgmt	Account state, KYC state, cards
GET /account/:userId/kyc-status	Account Mgmt	Issuer KYC status
POST /account/:userId/virtual	Virtual Cards	Create virtual-card account
GET /account/:userId/virtual/kyc-url	Virtual Cards	Hosted KYC session URL
GET /account/:userId/virtual/consent-agreement-url	Virtual Cards	Consent agreement URL
(referenced, unspecified) single-card order	Virtual Cards	Order the virtual card

Table 3: Complete issuer API surface received to date.

All six specified endpoints are integrated behind the issuer abstraction and exposed at `/v1/bank/cards/*`, with a deterministic sandbox simulation. Both guides assume the user *already exists* upstream and reference an API Reference not yet shared. Neither the base URL nor the authentication scheme has been issued; production credentials do not yet exist. The fee schedule (Platform Commercials) has been received and is published on docs.lux.financial.

5 Gap Summary

Priorities: **P0** blocks real-money launch of a product already built on the Lux side; **P1** blocks a committed near-term product; **P2** completes the portfolio.

Domain	P0	P1	P2
Platform fundamentals	6	1	—
Identity, IDV & onboarding	5	1	—
Accounts (ewallet + IBAN)	5	2	1
Payments & transfers	6	4	1
Cards (CaaS)	6	6	2
Webhooks & operations	3	3	1
Total: 54	31	17	5

Table 4: Missing issuer APIs by domain and priority.

6 Required APIs

Endpoint names below are proposals in the style of the received guides; equivalent contracts under different names are equally acceptable. “Lux surface” names the already-built product each item activates.

6.1 Platform fundamentals

Requirement	Contract	Pri	Lux surface
Base URLs	Sandbox + production hosts	P0	everything
Authentication scheme	Key issuance, header, rotation, IP allowlist	P0	everything
API Reference / OpenAPI	The reference both guides cite	P0	everything
Error catalog	Codes, retryability, human text	P0	everything
Idempotency	Idempotency-Key on all mutations	P0	payments, cards
Rate limits	Published limits + headers	P0	platform
Environments & fixtures	Sandbox test personas, funding simulator	P1	sandbox.lux.financial

6.2 Identity, IDV, and onboarding

Lux runs consumer IDV through lux.id (document capture, selfie liveness) and platform KYC through iam + amld, then hands the completed file to the bank. The hosted-URL flow works for cardholder KYC; account opening at scale requires server-to-server submission.

Requirement	Contract	Pri	Lux surface
User provisioning	POST /user — create the upstream user both guides presuppose; GET /user/:id	P0	signup at lux.finance
IDV document submission	POST /account/:userId/documents — identity document, proof of address, liveness artifact; multipart + metadata	P0	lux.id IDV hand-off
KYB (business)	Entity documents, UBOs, authorized signers	P0	business accounts
KYC decision webhook	kyc.approved / kyc.rejected with reason codes	P0	readiness without polling
Consent state webhook	consent.accepted	P0	card ordering flow
Re-KYC / refresh triggers	Periodic refresh, document expiry events	P1	compliance ops

6.3 Accounts — ewallet and IBAN

The fee schedule prices ewallet setup, wallet bank account setup, monthly and annual service, and dormancy. None of these products has an API yet.

Requirement	Contract	Pri	Lux surface
Open ewallet	POST /account/:userId/ewallet	P0	Silver tier
Open IBAN wallet bank account	POST /account/:userId/bank → returns IBAN/BIC	P0	Gold+ tiers, all IBAN products
Account details	GET .../details — IBAN, BIC, routing, reference	P0	dashboard, receiving funds
Balances	GET .../balance per currency	P0	balance reconciliation
Transaction history / statement	GET .../transactions, statement export	P0	activity feed, statements
Multi-currency sub-balances	USD/EUR/GBP at minimum	P1	multi-currency accounts
Account lifecycle	Close, freeze, dormancy state & fees	P1	account management
Interest / yield products	If offered	P2	savings

6.4 Payments and transfers

Every rail on the fee schedule is sold and priced; none has an API.

Requirement	Contract	Pri	Lux surface
Beneficiary registration	POST /beneficiary + verification state	P0	outbound payments
Domestic ACH (US), in/out	Originate + status lifecycle	P0	/v1/bank/payments/outbound
Wires — SWIFT, Fedwire	Originate, track, return handling	P0	Gold+ wire allowances
P2P ewallet transfer	POST /transfer ewallet→ewallet	P0	P2P
Ewallet ↔ bank transfer	Internal movement	P0	funding flows
Payment status webhooks	payment.settled / failed / returned	P0	transaction lifecycle
International ACH (local rails)	Originate + status	P1	cross-border payouts
FX quote / execute	Majors + exotics, quoted TTL	P1	/v1/bank/fx/*
Crypto-to-card settlement	Deposit address or settlement instruction API	P1	crypto funding
Paper checks (US/CA)	Issue + status	P1	check product
Incoming payment notification	Credit webhooks with payer data	P1	pay-ins
Bulk / batch payouts	Batched origination	P2	platform payouts

6.5 Cards — the CaaS surface

The account state exposes `cards[]` with `isLocked`, `isActivated`, `balance`, and a shipped physical card — implying capabilities that have no documented endpoint.

Requirement	Contract	Pri	Lux surface
Single-card order (spec)	The endpoint the Virtual Cards guide references	P0	virtual card issue
Physical card order	Plastic + metal, shipping address, status	P0	Gold/Black/Sovereign
Card activation	<code>POST /card/:id/activate</code>	P0	physical delivery flow
Card load / unload	Funding from ewallet or bank balance	P0	spend
Lock / unlock	<code>isLocked</code> is readable; make it writable	P0	freeze in-app
Authorization + transaction webhooks	Real-time auth events, clearing, declines	P0	activity, controls
Secure PAN reveal	Tokenized display (SDK / iframe / one-time token)	P1	card details in-app
PIN set / reset	Secure channel	P1	physical cards
Push provisioning	Apple Pay / Google Pay in-app provisioning payloads	P1	wallet add from app
Spending controls	Per-card limits, MCC rules	P1	tier controls
Replacement / cancel	Lost, stolen, damaged	P1	card lifecycle
3-D Secure	Enrollment + challenge callbacks	P1	e-commerce
Disputes / chargebacks	File, evidence, status	P2	support ops
Card-to-card transfer	Priced on the fee schedule	P2	transfers

6.6 Webhooks and operations

Requirement	Contract	Pri	Lux surface
Webhook delivery contract	Signed (HMAC), versioned events, retries	P0	every async flow
Event catalog	Complete typed event list	P0	integration correctness
Webhook replay	Re-fire by event id	P0	recovery, idempotency tests
Settlement / reconciliation files	Daily program-level settlement report	P1	finance ops
Fee reports	Itemized fee extraction matching the schedule	P1	pricing reconciliation
Program ledger / float	Program balance and funding API	P1	treasury
SLA + status page	Uptime commitments, incident channel	P2	operations

7 What Ships on Receipt

The Lux side is built and released (bankd v1.3.0). The issuer abstraction means each API above lands as an implementation detail — no client-visible change:

- **Identity + accounts (§6.2, 6.3)** activate real-money signup at lux.finance: lux.id IDV → document submission → bank approval → IBAN in the dashboard. The production flip is one deployment switch (`BANK_SANDBOX=false`) plus credentials in KMS.
- **Payments (§6.4)** activate the already-exposed `/v1/bank/transfers`, `/v1/bank/payments/outbound`, and FX routes against real rails, with plan allowances (free wires, ACH) metered by the membership ladder.

- **Cards (§6.5)** complete `/v1/bank/cards/*` — already live end-to-end in sandbox — into the full CaaS.
- **Agent surface:** the same contract publishes through `api.hanzo.ai` as `/v1/bank` and `/v1/cards` for agent and API customers, with MCP tools over the same routes.

8 Request Summary

Requested from SF Private Bank, in order:

1. The full API Reference both guides cite, with base URLs and the authentication scheme; sandbox credentials.
2. User provisioning and server-to-server IDV/KYB document submission (§6.2), with KYC decision webhooks.
3. Ewallet and IBAN account opening with account details, balances, and history (§6.3).
4. Payment origination on ACH and wires with beneficiary registration and status webhooks (§6.4).
5. The card lifecycle beyond ordering: physical orders, activation, load, lock, and authorization webhooks (§6.5).
6. The webhook delivery contract and event catalog (§6.6); reconciliation and fee reporting to follow.

With items 1–3, real-money accounts open at `lux.finance`. With 4, money moves. With 5–6, the complete BaaS and CaaS operates at production quality across every Lux surface.